MODULE 19 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Post-Quantum Cryptography

What a quantum computer would break, what it would not, and how ML-KEM and ML-DSA fit into AWS today.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 19 of 52

admin@sthithapragna.com

Quantum computers threaten **public-key** cryptography. The urgent risk is traffic recorded **today** and decrypted later.

What is at risk

CRYPTOGRAPHY	QUANTUM IMPACT	ACTION
RSA, ECDH key exchange	Broken	Move to ML-KEM, hybrid first
RSA, ECDSA signatures	Broken	Move to ML-DSA for long-lived trust
AES-256 at rest	Weakened, still strong	No change needed
SHA-256 and larger hashes	Weakened, still strong	No change needed

ON THE EXAM

Data at rest under AES-256 is not the problem. Re-encrypting it buys nothing.

ML-KEM or ML-DSA?

ML-KEM, FIPS 203

Agree a secret key

- Key encapsulation mechanism
- Replaces RSA and ECDH key exchange
- Protects confidentiality
- Used in hybrid TLS handshakes

ML-DSA, FIPS 204

Prove who signed it

- Digital signature algorithm
- Replaces RSA and ECDSA signatures
- Protects authenticity and integrity
- Code signing, certificates, roots of trust

THE TIEBREAKER

Keeping data secret means ML-KEM. Proving origin or integrity means ML-DSA.

Why hybrid key exchange?

- **Hybrid** combines a classical exchange such as ECDH with ML-KEM.
- **Secure if either holds:** classical against today, ML-KEM against tomorrow.
- **Industry norm now;** AWS expects pure post-quantum exchange later.
- **Negotiated in TLS 1.3:** clients that do not offer it fall back to classical.

> ON THE EXAM
>
> Hybrid is not a compromise. It is how AWS and the industry deploy ML-KEM today.

Hybrid post-quantum TLS on AWS

WHERE	STATUS
KMS, ACM, Secrets Manager, STS, IAM, S3	On server-side; update your clients
CloudFront, viewer to edge	On by default for all security policies
ALB and NLB listeners	Opt in: choose a PQ TLS security policy
Aurora, RDS, Transfer Family SFTP	Opt in: upgrade engine or change policy
Classic Load Balancer	Not planned; migrate away

ON THE EXAM

AWS endpoints are ready. Your load balancers and your clients are your responsibility.

Post-quantum keys in KMS

KEY SPEC	KEY USAGE	OPERATIONS
ML_DSA_44, 65, 87	SIGN_VERIFY	Sign, Verify, GetPublicKey
ML_KEM_512, 768, 1024	ENCAPSULATE_DECAPSULATE	Encapsulate, Decapsulate

ON THE EXAM

Post-quantum TLS protects calls to KMS. PQ keys in KMS are a separate feature for your own use.

Signatures and roots of trust

- **Long-lived trust first:** firmware, code signing, device roots of trust.
- **AWS Private CA** issues ML-DSA certificates and CAs.
- **KMS ML-DSA keys** sign artefacts, with keys never leaving the HSM.
- **Session authentication** is less urgent: it cannot be forged retroactively.

> ON THE EXAM
>
> Devices in the field for a decade need a post-quantum root of trust before they ship.

A post-quantum migration plan

01
Inventory
Find where public-key crypto is used

02
Prioritise
Long-lived secrets and long-lived trust first

03
Transit
Hybrid ML-KEM on listeners and clients

04
Signing
ML-DSA for code, firmware and roots

05
Agility
Make algorithms configurable, not coded in

ON THE EXAM

Crypto agility, swapping an algorithm by configuration, is the lasting goal.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Recorded traffic, decrypted in future	Hybrid ML-KEM TLS
Firmware or code trusted for many years	ML-DSA signatures
Re-encrypt stored data for quantum	Not needed; AES-256 holds
Agree a shared secret with a partner	ML-KEM key in KMS
ALB clients still use classical exchange	Listener PQ security policy
Endpoint supports PQ, logs show classical	Update the client

ON THE EXAM

Confidentiality: ML-KEM. Authenticity: ML-DSA. At rest: leave it.

> Meridian Freight's customs API carries trade data that must stay confidential for 20 years. It is served through an Application Load Balancer with a TLS 1.3 security policy.
>
> Security is concerned that traffic captured today could be decrypted by a future quantum computer.

What should the solutions architect do first?

A Re-encrypt the backing S3 data with a new customer managed key

B Change the ALB listener to a security policy that supports hybrid post-quantum key exchange, and update clients

C Replace the RSA 2048 certificate with an RSA 4096 certificate

D Wait until pure post-quantum key exchange is standardised

◆ PAUSE AND DECIDE

What should the solutions architect do first?

A Re-encrypt at rest

AES-256 at rest is not what a quantum computer breaks.

B PQ listener policy

Hybrid ML-KEM protects today's sessions against future decryption.

C Larger RSA key

Quantum attacks break RSA regardless of size.

D Wait

Every day of waiting adds recorded traffic to the harvest.

THE SIGNAL

Harvest now, decrypt later is fixed in the handshake, and ALB requires you to opt in.

> Meridian Freight is designing firmware for trailer telematics units that will stay in service for 15 years. Each unit must verify firmware updates before installing them.
>
> The signing key must be protected in a validated HSM and the scheme must remain trustworthy if large quantum computers appear.

Which approach should the solutions architect choose?

A ECDSA P-384 signing keys in KMS

B An ML-KEM key in KMS used to sign the firmware

C An ML-DSA signing key in KMS, with the public key provisioned into each unit before it ships

D RSA 4096 signing keys in CloudHSM

◆ PAUSE AND DECIDE

Which approach should the solutions architect choose?

A ECDSA P-384

Elliptic-curve signatures are broken by a quantum computer.

B ML-KEM

A key encapsulation mechanism. It cannot sign anything.

C ML-DSA in KMS

Post-quantum signatures, key held in KMS HSMs, root provisioned at manufacture.

D RSA 4096

Dedicated hardware does not make RSA quantum-safe.

THE SIGNAL

Signing plus long life plus quantum risk: ML-DSA, provisioned before the device ships.

> Meridian Freight's board asks for a post-quantum plan. A consultant proposes re-encrypting 4 PB of S3 and EBS data, currently encrypted with SSE-KMS under symmetric customer managed keys, as the first project.
>
> Most of the company's sensitive data also crosses the internet between partners and AWS.

What should the solutions architect advise?

A. Leave data at rest as it is, since KMS symmetric encryption remains quantum resistant, and prioritise post-quantum key exchange in transit

B. Re-encrypt all data under new symmetric keys

C. Move all data to a CloudHSM custom key store

D. Re-encrypt all data with ML-KEM keys in KMS

◆ PAUSE AND DECIDE

What should the solutions architect advise?

A Prioritise transit

Matches the risk: symmetric at rest holds; recorded traffic does not.

B New symmetric keys

Replaces strong keys with equally strong keys.

C CloudHSM key store

Changes who holds the key, not its quantum resistance.

D ML-KEM for bulk data

ML-KEM agrees keys; it does not encrypt data at rest.

THE SIGNAL

Start where quantum computers break things: public-key exchange in transit, not AES at rest.

> Meridian Freight and a customs authority must establish a shared secret so the authority can encrypt declarations that only Meridian can decrypt.
>
> Meridian's private key must never leave a FIPS-validated HSM, and the exchange must be quantum resistant.

What should the solutions architect use?

A. A KMS ECC key with KEY_AGREEMENT usage and DeriveSharedSecret

B. A KMS ML-DSA key shared with the authority

C. An RSA key pair stored in Secrets Manager

D. A KMS ML-KEM key: the authority encapsulates with Meridian's public key, and Meridian calls Decapsulate

◆ PAUSE AND DECIDE

What should the solutions architect use?

A ECDH key agreement

Keeps the key in an HSM, but elliptic-curve exchange is not quantum resistant.

B ML-DSA

Signs; cannot establish a shared secret.

C RSA in Secrets Manager

Not quantum resistant, and the key leaves an HSM.

D ML-KEM in KMS

Post-quantum key establishment; the private key stays in KMS.

THE SIGNAL

Shared secret, quantum resistant, private key in an HSM: an ML-KEM key in KMS.

> Meridian Freight wants every external entry point to offer hybrid post-quantum key exchange. Its estate includes a CloudFront distribution, a Network Load Balancer with TLS listeners, and applications calling the KMS and S3 APIs with current SDKs.
>
> The team wants to know which component needs a configuration change.

Which component requires the team to act?

A The CloudFront distribution's viewer connections

B The AWS KMS service endpoint

C The Network Load Balancer's TLS listeners

D The Amazon S3 service endpoint

◆ PAUSE AND DECIDE

Which component requires the team to act?

A CloudFront viewers

On by default for all security policies.

B KMS endpoint

Supported server-side; current SDKs can use it.

C NLB listeners

Opt in: select a PQ security policy on each listener.

D S3 endpoint

Supported server-side for all bucket types.

THE SIGNAL

AWS endpoints and CloudFront viewers: done for you. Your load balancer listeners: your job.

A Meridian Freight audit of CloudTrail records for AWS Secrets Manager shows that calls from an on-premises Java application still use classical key exchange.

Secrets Manager endpoints already support hybrid post-quantum TLS.

What should the solutions architect do?

A Enable post-quantum TLS in the Secrets Manager resource policy

B Upgrade the application's SDK and TLS client to versions that offer hybrid ML-KEM

C Ask AWS Support to enable post-quantum TLS for the account

D Route the calls through an AWS Site-to-Site VPN

◆ PAUSE AND DECIDE

What should the solutions architect do?

A Resource policy

No such setting; the server already supports it.

B Upgrade the client

The client must offer ML-KEM for the handshake to use it.

C Support case

Nothing to enable; it is already on server-side.

D Site-to-Site VPN

IPsec tunnels use their own classical key exchange.

THE SIGNAL

The server supports it but logs show classical: the client is not offering it.

What to carry out of this module

- **Quantum breaks public-key crypto;** AES-256 at rest stays strong.
- **Harvest now, decrypt later** makes transit key exchange the first fix.
- **ML-KEM** agrees secrets; **ML-DSA** signs. Never swap them.
- **AWS endpoints and CloudFront:** on. **ALB, NLB, databases:** opt in.
- **Inventory, prioritise by lifetime, and build for crypto agility.**

> ON THE EXAM
>
> Confidentiality: ML-KEM. Authenticity: ML-DSA. At rest: leave it.